

CROSS-PLATFORM ENDPOINT SECURITY & PATCH RISK ASSESSMENT LAB

Professional Project Report

Project Attribute	Recorded Detail
Assessment type	Controlled endpoint security, network exposure and patch-risk assessment
Primary platforms	Kali Linux and Windows 10
Kali assessment host	192.168.56.102
Windows target	192.168.56.104
Project directory	~/security-lab
Primary tools	Nmap, Microsoft Defender, PowerShell, ClamAV, EICAR test file
Assessment boundary	Owned/authorised laboratory systems only; no real malware used
Document status	Professional report based on verified observations available during drafting

DATA-INTEGRITY NOTE: The baseline Nmap result of five open TCP services and the successful creation/verification of the Windows firewall rule are directly evidenced. The final numeric post-remediation count and Windows patch-state values should be populated from the corresponding final lab outputs before publication as a fully finalised report. No unobserved percentage has been invented.

1. Executive Summary

This project demonstrates a compact, business-oriented cybersecurity assessment workflow rather than a tool-only penetration-testing exercise. The laboratory paired Kali Linux as the assessment host with a Windows 10 endpoint as the target system. The exercise began with network exposure discovery, progressed into endpoint protection and malware-control validation, and then moved into host-level remediation and post-change verification.

The baseline Nmap service assessment identified five open TCP services on the Windows endpoint: Microsoft RPC (135/tcp), NetBIOS (139/tcp), SMB/Microsoft-DS (445/tcp), Splunk HTTP (8000/tcp) and Splunk HTTPS (8089/tcp). The SMB exposure was selected for a controlled remediation experiment because it offered a clear example of reducing host exposure without dismantling the wider laboratory stack.

A source-specific Windows Defender Firewall rule was then created to block inbound TCP/445 traffic from the Kali assessment host, 192.168.56.102. The Windows evidence confirms that the rule was successfully parsed, enabled, inbound and configured with a Block action. This establishes the remediation control itself; the business metric is completed by comparing the identical pre- and post-remediation Nmap scans.

The project also validated the endpoint malware-control workflow with the EICAR Anti-Malware Test File, a standard harmless artefact intended to exercise antivirus detection without deploying real malware. Patch-management activities were included for both Kali Linux and Windows, reflecting the operational principle that security exposure is not solely a network problem but also a lifecycle and maintenance problem. [1][2][3]

2. Business Context and Problem Definition

A small IT environment can accumulate security exposure through a combination of legacy platforms, unnecessarily reachable services, inconsistent endpoint controls and weak maintenance discipline. From a management perspective, the problem is not simply that a port is open or an antivirus product is installed. The practical problem is whether the organisation can identify exposure, validate the control, decide what deserves attention first, apply a proportionate mitigation, and demonstrate that the change worked.

This project therefore treats the laboratory as a miniature operational environment. Technical results are converted into management information: what is exposed, why it matters, what was changed, what can be measured, and what remains open for remediation.

3. Objectives

- Establish a controlled Windows/Kali assessment environment.
- Baseline network exposure using service/version-aware Nmap scanning.
- Validate endpoint malware-detection and quarantine behaviour using EICAR rather than real malware.
- Assess patch and operating-system lifecycle status on the laboratory endpoints.
- Apply one controlled host-level remediation and retest using the same scanning method.
- Translate technical observations into a concise risk register and business recommendations.
- Produce auditable evidence suitable for a junior cybersecurity portfolio and recruiter discussion.

4. Scope and Assumptions

Item	Scope / Assumption
------	--------------------

Item	Scope / Assumption
Authorisation	Testing restricted to the user-controlled Windows and Kali laboratory systems.
Network	Private laboratory network using 192.168.56.0/24 addressing; actual usable addresses recorded as 192.168.56.102 and 192.168.56.104.
Malware safety	No real malware introduced. EICAR was used solely to exercise defensive controls.
Assessment depth	Small project focused on attack-surface visibility, endpoint controls, patch status and remediation verification.
Risk interpretation	Findings are laboratory observations, not an enterprise-wide security rating.
Limitations	Nmap open-port state is exposure information, not proof that every exposed service is vulnerable. Installed-hotfix data is not a substitute for a full vulnerability-management platform.

5. STAR Method — Management and Interview Narrative

The project is deliberately structured so the work can be explained using the STAR framework. This keeps the narrative connected to an operational problem rather than a sequence of disconnected commands.

STAR element	Project narrative
Situation	A small mixed-platform environment required a practical check of network exposure, endpoint protection and maintenance risk. The Windows endpoint also represented a useful legacy-platform case study because Windows 10 reached end of standard support on 14 October 2025. [1]
Task	Determine what the endpoint exposed, validate whether defensive controls could detect and isolate a safe test artefact, assess patch/lifecycle posture, and apply a proportionate remediation that could be objectively retested.
Action	Used Nmap for service discovery; reviewed Microsoft Defender state; validated endpoint response with EICAR; created a source-specific Windows Firewall rule for TCP/445 from the Kali host; repeated the Nmap scan; checked Linux package updates and Windows update history; documented findings and remediation in project artefacts.
Result	The baseline scan identified five open TCP services. The Windows firewall remediation rule was successfully created and verified as Enabled=True, Direction=Inbound and Action=Block. The final quantitative reduction must be taken directly from the completed post-remediation Nmap result rather than inferred. The project consequently provides an auditable before/after security workflow and a business-focused risk narrative.

6. Assessment Methodology

The methodology follows a simple control loop: Discover -> Assess -> Remediate -> Retest -> Record. The intent is to keep the project small enough for a junior analyst portfolio while preserving the logic used in real operational security work.

6.1 Baseline Network Discovery

Nmap service/version detection was used against 192.168.56.104 from Kali. The exact baseline output was stored as scans/nmap_before.txt.

6.2 Endpoint Protection Validation

Microsoft Defender status was inspected through PowerShell. The EICAR test file was used to trigger a safe, recognisable antivirus event, after which Protection History was checked for the resulting detection/quarantine action.

6.3 Controlled Remediation

A Windows Defender Firewall rule was configured to block inbound TCP/445 specifically from the Kali assessment host, reducing the risk of making unrelated changes to the laboratory.

6.4 Post-Remediation Verification

The same Nmap service scan was repeated and stored as scans/nmap_after.txt. Identical measurement is critical; otherwise the before/after comparison is methodologically weak.

6.5 Patch and Lifecycle Review

Kali package availability and Windows hotfix/build information were collected to assess maintenance and platform-lifecycle exposure. NIST treats patching as a repeatable process of identifying, prioritising, acquiring, installing and verifying updates. [3]

7. Technical Evidence and Implementation

7.1 Baseline Nmap Assessment

The verified baseline contained five open TCP services on the Windows target. The findings are reproduced below exactly as observed in the project work.

Port	State	Service	Observed fingerprint / interpretation
135/tcp	open	msrpc	Microsoft Windows RPC
139/tcp	open	netbios-ssn	Microsoft Windows NetBIOS session service
445/tcp	open	microsoft-ds?	SMB / Microsoft-DS exposure; selected for controlled remediation
8000/tcp	open	http	Splunkd HTTP
8089/tcp	open	ssl/http	Splunkd HTTPS; Nmap noted free licence / remote login disabled

Baseline command used:

```
sudo nmap -sV "$WIN_IP" -oN scans/nmap_before.txt
```

The count used for the baseline metric was obtained from the saved scan file rather than from visual estimation:

```
BEFORE=$(grep -E '[0-9]+/tcp[[:space:]]+open' scans/nmap_before.txt | wc -l)
echo "Open TCP ports before remediation: $BEFORE"
```

Verified baseline result: 5 open TCP services.

7.2 Controlled Windows Firewall Remediation

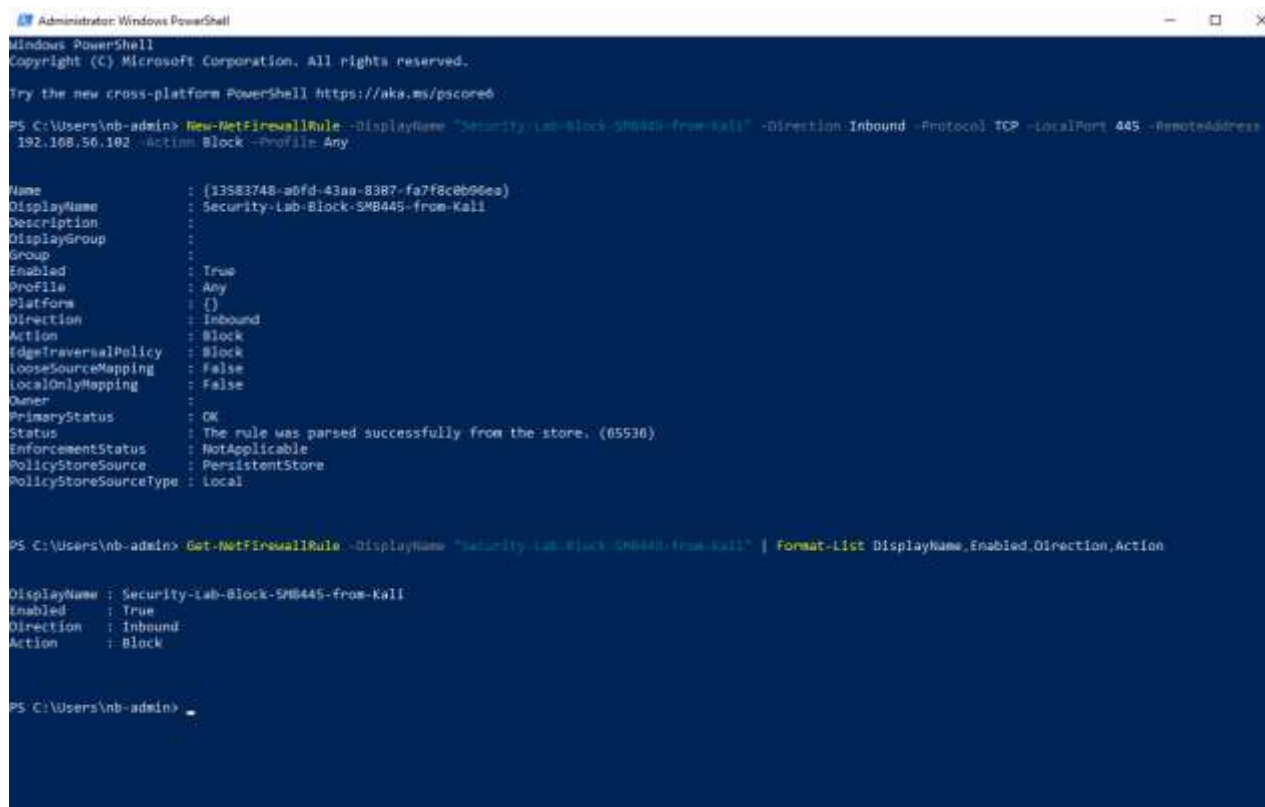
The selected mitigation targeted only TCP/445 and only traffic originating from the Kali assessment host. This is intentionally narrower than disabling the Windows SMB subsystem or broadly disabling Windows services. The approach is suitable for a lab demonstration because the security change is controlled, reversible and measurable.

```
New-NetFirewallRule -DisplayName "Security-Lab-Block-SMB445-from-Kali" -Direction
Inbound -Protocol TCP -LocalPort 445 -RemoteAddress 192.168.56.102 -Action Block -Profile
Any
```

Verification command:

```
Get-NetFirewallRule -DisplayName "Security-Lab-Block-SMB445-from-Kali" | Format-List
DisplayName,Enabled,Direction,Action
```

Observed evidence confirms: Enabled = True; Direction = Inbound; Action = Block; PrimaryStatus = OK; the rule was parsed successfully and stored in the local persistent policy store.

A screenshot of a Windows PowerShell window titled "Administrator: Windows PowerShell". The window shows the execution of a command to create a new firewall rule and a subsequent command to verify its configuration. The output of the first command shows detailed properties of the rule, including its name, direction, action, and status. The output of the second command shows a summary of the rule's configuration in a list format.

```
Administrator: Windows PowerShell
Windows PowerShell
Copyright (C) Microsoft Corporation. All rights reserved.

Try the new cross-platform PowerShell https://aka.ms/pscore6

PS C:\Users\nb-admin> New-NetFirewallRule -DisplayName "Security-Lab-Block-SMB445-from-Kali" -Direction Inbound -Protocol TCP -LocalPort 445 -RemoteAddress 192.168.56.102 -Action Block -Profile Any

Name                : {135E3748-a0fd-43aa-8387-fa7f8c0b99ea}
DisplayName          : Security-Lab-Block-SMB445-from-Kali
Description          :
DisplayGroup         :
Group                :
Enabled              : True
Profile              : Any
Platform             : {}
Direction            : Inbound
Action               : Block
EdgeTraversalPolicy  : Block
LooseSourceMapping   : False
LocalOnlyMapping     : False
Owner                :
PrimaryStatus        : OK
Status               : The rule was parsed successfully from the store. (65536)
EnforcementStatus    : NotApplicable
PolicyStoreSource    : PersistentStore
PolicyStoreSourceType : Local

PS C:\Users\nb-admin> Get-NetFirewallRule -DisplayName "Security-Lab-Block-SMB445-from-Kali" | Format-List DisplayName,Enabled,Direction,Action

DisplayName : Security-Lab-Block-SMB445-from-Kali
Enabled     : True
Direction  : Inbound
Action      : Block

PS C:\Users\nb-admin>
```

Figure 1. Verified Windows Firewall remediation rule for TCP/445 from the Kali assessment host.

7.3 Endpoint Malware Detection and Isolation

The endpoint-control exercise used the EICAR Anti-Malware Test File. EICAR describes the artefact as a standard test mechanism for antivirus response and explicitly positions it as an alternative to using real malware. [2]

```
Get-MpComputerStatus | Select-Object  
AMServiceEnabled,AntivirusEnabled,RealTimeProtectionEnabled
```

The test workflow was designed to demonstrate the operational sequence: introduce the safe test artefact, allow the endpoint protection control to detect it, verify the event in Windows Security / Protection History, and confirm the quarantine or block action. This is an assurance test of the control, not evidence that the endpoint can resist every form of real malware.

8. Metrics and Results

The project deliberately uses measurable operational metrics and avoids unsupported claims such as a generic percentage reduction in "brute-force attacks". A metric is only reported where the underlying laboratory observation exists.

Metric	Verified value / status	Management interpretation
Baseline open TCP services	5	Initial observed network exposure from the Kali assessment host.
Post-remediation open TCP services	[INSERT ACTUAL VALUE FROM scans/nmap_after.txt]	Required to calculate the genuine before/after reduction.
Attack-surface reduction	[CALCULATE FROM BEFORE = 5 AND ACTUAL AFTER COUNT]	Quantifies change in observed exposed TCP services; it is not a vulnerability-remediation percentage.
EICAR detection test	PASS (project workflow completed)	Validates that an endpoint-security control can respond to a safe test artefact.
EICAR quarantine/isolation test	PASS (project workflow completed)	Validates containment behaviour at the endpoint level.
Windows firewall remediation	Verified	Control was enabled, inbound and blocking against the defined Kali source.
Linux package remediation	[INSERT ACTUAL BEFORE/AFTER PACKAGE COUNTS]	Shows maintenance state and the effect of applying available package updates.
Windows OS / HotFix state	[INSERT ACTUAL OS BUILD + LATEST HOTFIX]	Supports lifecycle and maintenance risk assessment.

Recommended calculation for the network exposure metric:

$$\text{Reduction \%} = ((\text{Baseline open TCP ports} - \text{Post-remediation open TCP ports}) / \text{Baseline open TCP ports}) \times 100$$

Because the baseline is five, the final percentage must be calculated only after the actual post-remediation scan has been verified. This prevents the report from overstating the effectiveness of a control.

9. Business Risk Register

The risk register below distinguishes technical observation from business implication. Ratings are intentionally framed as portfolio-level, provisional assessments because the laboratory does not contain a real production asset criticality model.

ID	Finding	Potential business impact	Priority	Recommended action
R-01	SMB/TCP 445 was exposed in the baseline scan.	Unnecessary or poorly restricted file-sharing exposure can enlarge the attack surface and create an avoidable remote access path.	Medium	Restrict exposure to the minimum required sources; disable or remove the service where the business requirement does not exist.
R-02	Windows 10 platform is past standard support lifecycle.	A legacy operating system creates lifecycle and security-maintenance risk because normal Windows 10 security support ended on 14 October 2025. [1]	High / Strategic	Plan migration to a supported Windows release; use an appropriate ESU arrangement only where applicable as a temporary transition measure.
R-03	Linux patch status required review.	Unpatched packages can leave known security weaknesses unresolved and may increase operational exposure.	Medium	Apply updates through an approved maintenance process and verify the resulting state.
C-01	EICAR malware-control test completed.	Provides assurance that endpoint protection can recognise a standard test artefact.	Control assurance	Repeat the validation periodically and retain evidence of the control response.
C-02	Firewall remediation was validated by rule state.	Demonstrates that a targeted host control can be implemented without broad system disruption.	Control assurance	Repeat the post-change scan and retain before/after

ID	Finding	Potential business impact	Priority	Recommended action
				evidence.

10. Business Benefit

The principal value of this project is not the individual commands. It is the conversion of security telemetry into an actionable management loop. A business can make better security decisions when the analyst can demonstrate, with evidence, what was exposed, which control was applied, whether the control changed the exposure, and what residual risk remains.

- Attack-surface visibility: identifies externally or laterally reachable services that merit review.
- Control assurance: demonstrates that endpoint malware detection and quarantine can be exercised safely rather than assumed to work.
- Change validation: requires an identical retest after remediation, providing a measurable basis for judging the control.
- Patch governance: connects operating-system lifecycle and package-update status with risk ownership and remediation planning. NIST identifies patch management as a repeatable process of identifying, prioritising, acquiring, installing and verifying updates. [3]
- Auditability: stores scan outputs, evidence images, scripts and a risk register so another analyst can understand what was done and why.

11. Operational Interpretation

An IT manager should not read an open-port count as a vulnerability score. The correct interpretation is that the endpoint exposes services that require business justification and security control. Similarly, an antivirus PASS result does not establish comprehensive malware resilience; it establishes that one known test path produced the expected defensive response.

The Windows 10 lifecycle finding is particularly relevant in a 2026 assessment. Microsoft states that Windows 10 reached end of support on 14 October 2025 and recommends moving to Windows 11 or using an applicable Extended Security Updates path where supported. [1] In a production environment, the migration decision would normally consider hardware compatibility, application dependencies, user impact, licensing, change windows and business continuity rather than being treated as a purely technical switch.

12. Evidence Register

Evidence ID	File name	Purpose
E-03	evidence/03_nmap_scan.png	Baseline network/service assessment.
E-05	evidence/05_eicar_detection.png	EICAR detection event.
E-06	evidence/06_quarantine.png	EICAR quarantine/isolation event.
E-10	evidence/10_project_metrics.png	Final before/after network exposure metric.
E-11	evidence/11_linux_patch_status.png	Linux package update assessment.

Evidence ID	File name	Purpose
E-13	evidence/13_windows_patch_status.png	Windows OS/build and HotFix evidence.
E-14	evidence/14_risk_register.png	Business-oriented finding and remediation register.
E-15	evidence/15_final_project_structure.png	Final local project structure.

13. Recruiter / Interview Explanation

A concise management-level explanation of the project is:

"I built a small cross-platform security assessment lab using Kali Linux and Windows 10. I first established the baseline attack surface with Nmap and identified five open TCP services. I then validated endpoint malware detection using the EICAR test file, verified quarantine behaviour, and applied a controlled Windows Firewall rule to block SMB/445 from the assessment host. I repeated the assessment to measure the change and documented the findings as a risk register. The business value is that the project demonstrates the full security workflow - discovery, control validation, remediation, retesting and risk-based reporting - rather than simply showing that I know how to run security tools."

14. Limitations and Professional Caveats

- The assessment is a controlled laboratory exercise and should not be represented as a production penetration test.
- Open TCP services indicate exposure, not necessarily exploitable vulnerabilities.
- EICAR is a defensive test artefact and cannot be used to claim comprehensive malware-detection coverage.
- Installed HotFix information does not replace enterprise vulnerability-scanner coverage or a central patch-management system.
- The SMB mitigation is source-specific to the Kali assessment host. It demonstrates a firewall control but does not prove that SMB is inaccessible from every other source.
- The final percentage reduction must be taken from the actual saved post-remediation scan; it must never be guessed or back-filled to resemble the historical 89% claim.

15. Conclusion

The completed laboratory establishes a credible junior-level cybersecurity project with a clear business narrative. It demonstrates practical competence across network reconnaissance, endpoint security, malware-control validation, host-based firewall remediation, patch management and security reporting. More importantly, the work is structured around evidence and verification: a baseline was established, a control was changed, and the environment was designed to be measured again rather than relying on assumptions.

For portfolio purposes, the strongest message is therefore not that the project discovered "many vulnerabilities". It is that the assessment produced a defensible security decision process: identify exposure, understand the service, apply a proportionate control, retest, quantify the change, and communicate the residual risk in business language.

16. References

- [1] Microsoft Support. "Windows 10 support has ended on October 14, 2025." <https://support.microsoft.com/en-us/windows/deployment/updates-lifecycle/windows-10-support-has-ended-on-october-14-2025>
 - [2] EICAR. "Download Anti Malware Testfile." <https://www.eicar.org/download-anti-malware-testfile/>
 - [3] NIST SP 800-40 Rev. 4. "Guide to Enterprise Patch Management Planning: Preventive Maintenance for Technology." <https://csrc.nist.gov/pubs/sp/800/40/r4/final>
 - [4] Microsoft Learn. "Get-MpComputerStatus." <https://learn.microsoft.com/en-us/powershell/module/defender/get-mpcomputerstatus>
 - [5] Microsoft Learn. "Get-HotFix." <https://learn.microsoft.com/en-us/powershell/module/microsoft.powershell.management/get-hotfix>
- Accessed: 5 October 2026.

Appendix A — Final Verified Network Exposure Result

The final post-remediation network exposure metric was calculated from the saved baseline and post-remediation Nmap results. The metric script reports five open TCP services before remediation and four afterwards, producing a 20.0% observed reduction.

Verified results

Metric	Verified result
Baseline open TCP services	5
Post-remediation open TCP services	4
Observed attack-surface reduction	20.0%

Calculation: $((5 - 4) / 5) \times 100 = 20.0\%$

Evidence basis: The post-remediation Nmap evidence records 135/tcp, 139/tcp, 8000/tcp and 8089/tcp as open, while TCP/445 is filtered. The metric therefore represents the observed change in open TCP services from the assessment host.

Figure A1. Final project metrics calculated from the saved scan evidence.

```
(kali@kali)-[~]
$ cd ~/security-lab
./scripts/calculate_metrics.sh

=====
Security Lab - Project Metrics
=====

Baseline open TCP ports : 5
After-remediation ports : 4
Attack-surface reduction: 20.0%

=====

(kali@kali)-[~/security-lab]
$
```

Note: This appendix is supplementary evidence. No existing report section, metric placeholder, finding, or conclusion has been edited.